Glitter: מחקר אבטחה

במסמך זה נתעד את כל תהליך הבדיקות של שלב א', גם את הבדיקות שהניבו פרי וגם את אלו שלא – פשוט הכל! בסיום המסמך יש סיכום של כל החולשות שנמצאו ומוגשות. יחד עם המסמך יש להגיש את קבצי ה-py של הוכחות ההיתכנות.

1. חלק א' – מחקר פרוטוקול כללי

השתמש בכלי המחקר הרגילים שלנו כדי לאסוף מאפיינים כלליים על הפרוטוקול.

שם פרוטוקול	Glitter
מעל TCP/UDP	TCP
פורט	1336
מאפייני פרוטוקול	טקסטואלי, stateful
פורמט כללי של בקשה	Request_Number#{gli&&er}{field_name:field_value}##
פורמט כללי של תגובה	Response_Number#Command_Description#{gli&&er}{field_name:field_value}##

קראו למדריכ/ה לפני שאתם ממשיכים לשלב הבא!

2. חלק ב' - סיכום חולשות

יש למלא חלק זה <u>תוך כדי מילוי של חלק ג'</u>. אם אתם בסייקל הראשון בכיתה – **דלגו על הטבלה** ועברו לחלק ג' כעת.

חולשות שנמצאו			
הסבר על החולשה שנמצאה	**כיצד תוקף יכול לנצל זאת (למה לא רוצים שדבר כזה יהיה אפשרי)**	**סקריפט POC מצורף**	**הצעה לפתרון**
ביצוע לייק למזהה גליט שאינו קיים.	התנהגות לא צפויה, ביצוע לייקים לגליטים שאינם קיימים.	שלוחות 1, 1 בתפריט.	הוספת בדיקה האם מזהה הגליט קטן ממזהה הגליט האחרון שפורסם באתר.
ביצוע לייק לגליט של משתמש פרטי שאיני אחד מחבריו.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, ביצוע לייקים לגליט של אנשים פרטיים שאינם רוצים בחברתו.	שלוחות 1, 2 בתפריט.	הוספת בדיקה האם מפרסם הגליט הוא אחד מחבריו של המשתמש, אם כך הדבר, תינתן האפשרות לבצע לייק.
ביצוע לייק תוך שינוי שם המסך לשם קצר מחמש תווים או ריק.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 1, 3 בתפריט.	הוספת בדיקה האם שם המסך גדול מ-5 תווים.
ביצוע לייק תוך שינוי שם המסך לשם שאינו קיים במערכת.	התנהגות לא צפויה, ביצוע לייקים על ידי משתמשים שאינם קיימים.	שלוחות 1, 3 בתפריט.	הוספת בדיקה האם שם המסך קיים במערכת.
ביצוע לייק פעמיים לגליט.	זיוף, ביצוע מספר מרובה של לייקים לגליט על ידי משתמש יחיד.	שלוחות 1, 4 בתפריט.	הוספת שדה בוליאני שאומר אם המשתמש כבר ביצע לייק לגליט זה בעבר.
הסרת לייק שנעשה על ידי משתמש אחר.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, מחיקת לייקים של משתמשים אחרים.	שלוחות 1, 5 בתפריט.	הוספת בדיקה האם הלייק בוצע במקור על ידי אותו המשתמש (על ידי מזהה הלייק).
חשיפת מזהה הגליט בעת ביצוע לייק.	דליפת מידע, קבלת מידע אודות גליט שאינו בבעלות המשתמש.	שלוחות 1, 6 בתפריט.	הצפנת השדה בתגובה.
פרסום תגובה למזהה גליט שאינו קיים.	התנהגות לא צפויה, פרסום תגובות לגליטים שאינם קיימים.	שלוחות 2, 1 בתפריט.	הוספת בדיקה האם מזהה הגליט קטן ממספר הגליט האחרון שפורסם באתר.
פרסום תגובה לגליט של משתמש פרטי שאיני אחד מחבריו.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, פרסום תגובות בגליט של אנשים פרטיים שאינם רוצים בחברתו.	שלוחות 2, 2 בתפריט.	הוספת בדיקה האם מפרסם הגליט הוא אחד מחבריו של המשתמש, אם כך הדבר, תינתן האפשרות לפרסם תגובה.

פרסום תגובה תוך שינוי שם המסך לשם קצר מחמש תווים או ריק.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 2, 3 בתפריט.	הוספת בדיקה האם שם המסך גדול מ-5 תווים.
פרסום תגובה תוך שינוי שם המסך לשם שאינו קיים במערכת.	התנהגות לא צפויה, פרסום תגובות על ידי משתמשים שאינם קיימים.	שלוחות 2, 3 בתפריט.	הוספת בדיקה האם שם המסך קיים במערכת.
פרסום תגובה ללא תוכן [PATCHED].	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 2, 4 בתפריט.	הוספת בדיקה האם תוכן התגובה גדול מאפס תווים.
פרסום תגובה שתוכנה ארוך מ-140 תווים.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 2, 5 בתפריט.	הוספת בדיקה האם תוכן התגובה קטן או שווה ל-140 תווים.
פרסום תגובה בזמן עבר או עתיד.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 2, 7/6 בתפריט.	הסרת השדה מהבקשה, השרת יקבע אצלו את זמן הפרסום בעת שקיבל את הבקשה, לא הלקוח.
ביצוע HTML Injection בשדה התוכן של בקשת פרסום התגובה.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 2, 8 בתפריט.	חסימת תווים מיוחדים מתוכן התגובה: '<', '>', '/' וכו'.
חשיפת מזהה הגליט בעת פרסום תגובה.	דליפת מידע, קבלת מידע אודות גליט שאינו בבעלות המשתמש.	שלוחות 2, 9 בתפריט.	הצפנת השדה בתגובה.
ביצוע וואו לגליט.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, פיצ'ר שאינו קיים בממשק הגרפי של האתר.	שלוחה 3 בתפריט.	הוספת הפיצ'ר בממשק הגרפי של האתר או לחלופין הסרת טיפולו מהשרת.
ביצוע וואו למזהה גליט שאינו קיים.	התנהגות לא צפויה, ביצוע וואו לגליטים שאינם קיימים.	שלוחות 3, 1 בתפריט.	הוספת בדיקה האם מזהה הגליט קטן ממספר הגליט האחרון שפורסם באתר.
ביצוע וואו לגליט של משתמש פרטי שאיני אחד מחבריו.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, ביצוע וואו לגליט של אנשים פרטיים שאינם רוצים בחברתו.	שלוחות 3, 2 בתפריט.	הוספת בדיקה האם מפרסם הגליט הוא אחד מחבריו של המשתמש, אם כך הדבר, תינתן האפשרות לבצע וואו.
ביצוע וואו תוך שינוי שם המסך לשם קצר מחמש תווים או ריק.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 3, 3 בתפריט.	הוספת בדיקה האם שם המסך גדול מ-5 תווים.

Glitter

ביצוע וואו תוך שינוי שם המסך לשם שאינו קיים במערכת.	התנהגות לא צפויה, ביצוע וואו על ידי משתמשים שאינם קיימים.	שלוחות 3, 3 בתפריט.	הוספת בדיקה האם שם המסך קיים במערכת.
ביצוע וואו פעמיים לגליט.	זיוף, ביצוע מספר מרובה של וואו לגליט על ידי משתמש יחיד.	שלוחות 3, 4 בתפריט.	הוספת שדה בוליאני שאומר אם המשתמש כבר ביצע וואו לגליט זה בעבר.
הסרת וואו שנעשה על ידי משתמש אחר.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, מחיקת וואו של משתמשים אחרים.	שלוחות 3, 5 בתפריט.	הוספת בדיקה האם הוואו בוצע במקור על ידי אותו המשתמש (על ידי מזהה הוואו).
חשיפת מזהה הגליט בעת ביצוע וואו.	דליפת מידע, קבלת מידע אודות גליט שאינו בבעלות המשתמש.	שלוחות 3, 6 בתפריט.	הצפנת השדה בתגובה.
פרסום גליט בפיד של משתמש פרטי שאיני אחד מחבריו.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, פרסום גליטים בפיד של אנשים פרטיים שאינם רוצים בחברתו.	שלוחות 4, 1 בתפריט.	הוספת בדיקה האם בעל הפיד הוא אחד מחבריו של המשתמש, אם כך הדבר, תינתן האפשרות לפרסם גליט.
פרסום גליט תוך שינוי שם המסך לשם קצר מחמש תווים או ריק בפיד של משתמש אחר.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 4, 2 בתפריט.	הוספת בדיקה האם שם המסך גדול מ-5 תווים.
פרסום גליט תוך שינוי שם המסך לשם שאינו קיים במערכת בפיד של משתמש אחר.	התנהגות לא צפויה, פרסום גליטים על ידי משתמשים שאינם קיימים.	שלוחות 4, 2 בתפריט.	הוספת בדיקה האם שם המסך קיים במערכת.
פרסום גליט ללא תוכן [PATCHED].	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 4, 3 בתפריט.	הוספת בדיקה האם תוכן הגליט גדול מאפס תווים.
פרסום גליט שתוכנו ארוך מ-140 תווים.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 4, 4 בתפריט.	הוספת בדיקה האם תוכן הגליט קטן או שווה ל-140 תווים.
פרסום גליט בזמן עבר או עתיד.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 4, 5/6 בתפריט.	הסרת השדה מהבקשה, השרת יקבע אצלו את זמן הפרסום בעת שקיבל את הבקשה, לא הלקוח.
ביצוע HTML Injection בשדה התוכן של בקשת פרסום גליט.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 4, 7 בתפריט.	חסימת תווים מיוחדים מתוכן הגליט: '<', '>', '/' וכו'.
פרסום גליט תוך שינוי האווטאר לאווטאר שונה מהמוגדר במשתמש.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, פיצ'ר שאינו קיים בממשק הגרפי של האתר.	שלוחות 4, 8 בתפריט.	הוספת הפיצ'ר בממשק הגרפי של האתר או לחלופין הסרת השדה מהבקשה.



פרסום גליט תוך שינוי צבע הפונט.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, פיצ'ר שאינו קיים בממשק הגרפי של האתר.	שלוחות 4, 9 בתפריט.	הוספת הפיצ'ר בממשק הגרפי של האתר או לחלופין הסרת השדה מהבקשה.
פרסום גליט תוך שינוי צבע הרקע לצבע שאינו קיים במערכת.	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים, צבע שאינו קיים בממשק הגרפי של האתר.	שלוחות 4, 10 בתפריט.	הוספת בדיקה האם צבע הרקע שהוכנס תואם לאחת האופציות בממשק הגרפי של האתר.
ביצוע הרשמה עם קוד הרשמה קצר מ-5 תווים.	התנהגות לא צפויה.	שלוחות 5, 1 בתפריט.	הוספת בדיקה האם קוד ההרשמה קצר מ-5 תווים.
ביצוע הרשמה עם שם מסך קצר מ-5 תווים [PATCHED].	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 5, 2 בתפריט.	הוספת בדיקה האם שם המסך קצר מ-5 תווים.
ביצוע הרשמה עם שם משתמש קצר מ-5 תווים [PATCHED].	התנהגות לא צפויה.	שלוחות 5, 3 בתפריט.	הוספת בדיקה האם שם המשתמש קצר מ-5 תווים.
ביצוע הרשמה עם כתובת מייל ריקה [PATCHED].	התנהגות לא צפויה.	שלוחות 5, 4 בתפריט.	הוספת בדיקה שדה כתובת המייל חוקי.
ביצוע חיפוש ריק.	התנהגות לא צפויה.	שלוחות 6, 1 בתפריט.	הוספת בדיקה האם המחרוזת לחיפוש מכילה תו אחד ומעלה.
חשיפת מזהה של משתמש וכתובת המייל של משתמש בעת ביצוע חיפוש לפי שם המסך של המשתמש.	דליפת מידע, קבלת מידע אודות משתמשים אחרים.	שלוחות 6, 2 בתפריט.	הסתרת השדות מהתגובה.
עדכון שם המסך לשם קצר מ-5 תווים [PATCHED].	התנהגות לא צפויה הגורמת לבלבול משתמשים אחרים.	שלוחות 7, 1 בתפריט.	הוספת בדיקה האם שם המסך גדול מ-5 תווים.
חשיפת שם משתמש של משתמש אחר בעת ניסיון עדכון הגדרות לפי מזהה המשתמש.	דליפת מידע, קבלת מידע אודות משתמשים אחרים.	שלוחות 7, 2 בתפריט.	הסתרת השדה מהתגובה.
חשיפת סיכום הביקורת של סיסמת משתמש: חשיפת מזהה המשתמש בעת	דליפת מידע, קבלת מידע אודות משתמשים אחרים.	שלוחות 8, 1 בתפריט.	הסתרת השדות מהתגובות.

ביצוע חיפוש לפי שם המסך של המשתמש -> חשיפת שם המשתמש בעת ניסיון עדכון הגדרות לפי מזהה המשתמש -> חשיפת סיכום הביקורת של המשתמש בעת ניסיון התחברות עם שם המשתמש וסיסמא שגויה -> חישוב וחיסור סיכום הביקורת של שם המשתמש מסיכום הביקורת הכולל של המשתמש.			

3. חלק ג' – מחקר נק' כניסה

השתמשו בטבלה הבאה בתור תבנית – שכפלו אותה עבור כל נק' כניסה שאתם חוקרים.
נק' כניסה היא בקשה ספציפית בפרוטוקול.
זכרו לשאול את עצמכם את השאלות הבאות:

- איזו דרך יש לתקוף כל פרמטר בפני עצמו?
- איזו דרך יש שעצם הבקשה תהיה תקיפה?

יש לשכפל את 2 הטבלאות האלה עבור כל נק' כניסה

Glitter

מחקר נק' כניסה	
מספר הבקשה	**710**
שם הבקשה בעברית	**לייק**
דוגמא אמיתית	710#{gli&&er}{"glit_id":164804,"user_id":68793,"user_screen_name":"lorem_ipsum","id":-1}##
תפקיד הבקשה	ביצוע לייק לגליט
תיאור פרמטרים	**שם** / **הסבר** glit_id / מזהה הגליט user_id / מזהה המשתמש user_screen_name / שם המסך של המשתמש id / מזהה הלייק
דוגמא אמיתית לתגובה	715#Like publish approved{gli&&er}{"glit_id":164804,"user_id":68793,"user_screen_name":"lorem_ipsum","id":2150319,"date":"2026-09-25T21:07:18.020Z"}##

תרחישי תקיפה לנק' כניסה

תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה

החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח
ביצוע לייק למזהה גליט שאינו קיים.	**Tampring**	**הצליח**
ביצוע לייק לגליט של משתמש פרטי שאיני אחד מחבריו.	**Tampring**	**הצליח**
ביצוע לייק תוך שינוי שם המסך לשם קצר מחמש תווים או ריק.	**Tampring**	**הצליח**
ביצוע לייק תוך שינוי שם המסך לשם שאינו קיים במערכת.	**Tampring**	**הצליח**
ביצוע לייק פעמיים לגליט.	**Other**	**הצליח**
חשיפת מזהה הגליט בעת ביצוע לייק.	**Information Disclosure**	**הצליח**
ביצוע לייק תוך שינוי מזהה המשתמש למזהה של משתמש אחר.	**Spoofing**	**לא הצליח**
ביצוע לייק תוך שינוי מזהה המשתמש למזהה משתמש שאינו קיים.	**Spoofing**	**לא הצליח**

Glitter

מחקר נק' כניסה	
מספר הבקשה	**650**
שם הבקשה בעברית	**תגובה**
דוגמא אמיתית	650#{gli&&er}{"glit_id":164807,"user_id":68793,"user_screen_name":"lorem_ipsum","id":-1,"content":"lorem_ipsum","date":"2026-09-26T00:09:22.109197Z"}##
תפקיד הבקשה	פרסום תגובה לגליט
תיאור פרמטרים	**שם** / **הסבר**: glit_id – מזהה הגליט; user_id – מזהה המשתמש; user_screen_name – שם המסך של המשתמש; id – מזהה התגובה; content – תוכן התגובה; date – זמן פרסום התגובה
דוגמא אמיתית לתגובה	Comment publish 655# approved{gli&&er}{"glit_id":164807,"user_id":68793,"user_screen_name":"lorem_ipsum","id"##:65257,"date":"2026-09-26T00:09:22.109197Z","content":"lorem_ipsum"}

תרחישי תקיפה לנק' כניסה

תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה

החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח
פרסום תגובה למזהה גליט שאינו קיים.	**Tampring**	**הצליח**
פרסום תגובה לגליט של משתמש פרטי שאיני אחד מחבריו.	**Tampring**	**הצליח**
פרסום תגובה תוך שינוי שם המסך לשם קצר מחמש תווים או ריק.	**Tampring**	**הצליח**
פרסום תגובה תוך שינוי שם המסך לשם שאינו קיים במערכת.	**Tampring**	**הצליח**
פרסום תגובה ללא תוכן [PATCHED].	**Tampring**	**הצליח**
פרסום תגובה שתוכנה ארוך מ-140 תווים.	**Tampring**	**הצליח**
פרסום תגובה בזמן עבר או עתיד.	**Tampring**	**הצליח**
ביצוע HTML Injection בשדה התוכן של בקשת פרסום התגובה.	**Tampring**	**הצליח**
חשיפת מזהה הגליט בעת פרסום תגובה.	**Information Disclosure**	**הצליח**
פרסום תגובה תוך שינוי מזהה המשתמש למזהה של משתמש אחר.	**Spoofing**	**לא הצליח**
פרסום תגובה תוך שינוי מזהה המשתמש למזהה משתמש שאינו קיים.	**Spoofing**	**לא הצליח**

Glitter

מחקר נק' כניסה		
מספר הבקשה	**750**	
שם הבקשה בעברית	**וואו**	
דוגמא אמיתית	750#{gli&&er}{"user_id":68793,"user_screen_name":"lorem_ipsum","glit_id":164807}##	
תפקיד הבקשה	ביצוע וואו לגליט	
תיאור פרמטרים	**שם**	**הסבר**
	user_id	מזהה המשתמש
	user_screen_name	שם המסך של המשתמש
	glit_id	מזהה הגליט
דוגמא אמיתית לתגובה	Wow pulish 755# approved{gli&&er}{"glit_id":164807,"user_id":68793,"user_screen_name":"lorem_ipsum","id"##:14334,"date":"2026-09-25T21:12:02.857Z"}	

תרחישי תקיפה לנק' כניסה

תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה

החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח
ביצוע וואו למזהה גליט שאינו קיים.	**Spoofing**	**הצליח**
ביצוע וואו לגליט של משתמש פרטי שאיני אחד מחבריו.	**Tampring**	**הצליח**
ביצוע וואו תוך שינוי שם המסך לשם קצר מחמש תווים או ריק.	**Tampring**	**הצליח**
ביצוע וואו תוך שינוי שם המסך לשם שאינו קיים במערכת.	**Tampring**	**הצליח**
ביצוע וואו פעמיים לגליט.	**Tampring**	**הצליח**
חשיפת מזהה הגליט בעת ביצוע וואו.	**Information Disclosure**	**הצליח**
ביצוע וואו תוך שינוי מזהה המשתמש למזהה של משתמש אחר.	**Spoofing**	**לא הצליח**
ביצוע וואו תוך שינוי מזהה המשתמש למזהה משתמש שאינו קיים.	**Spoofing**	**לא הצליח**

Glitter

מחקר נק' כניסה

מספר הבקשה	**550**
שם הבקשה בעברית	**פרסום גליט**
דוגמא אמיתית	550#{gli&&er}{"feed_owner_id":68793,"publisher_id":68793,"publisher_screen_name":"lorem_ipsum","publisher_avatar":"im4","background_color":"OrangeRed","date":"2026-09-26T00:19:58.903702Z","content":"lorem_ipsum","font_color":"black","id":-1}##
תפקיד הבקשה	פרסום גליט בפיד
תיאור פרמטרים	

שם	הסבר
feed_owner_id	מזהה המשתמש של בעל הפיד
publisher_id	מזהה המשתמש של מפרסם הגליט
publisher_screen_name	שם המסך של מפרסם הגליט
publisher_avatar	האווטאר של מפרסם הגליט
background_color	צבע הרקע של הגליט
date	זמן פרסום הגליט
content	תוכן הגליט
font_color	צבע כיתוב הגליט
id	מזהה הגליט

דוגמא אמיתית לתגובה	555#Glit publish approved{gli&&er}{"feed_owner_id":68793,"publisher_id":68793,"publisher_screen_name":"lorem_ipsum","publisher_avatar":"im4","background_color":"OrangeRed","date":"2026-09-##26T00:19:58.903702Z","content":"lorem_ipsum","font_color":"black","id":164811}

תרחישי תקיפה לנק' כניסה

תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה

החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח
פרסום גליט בפיד של משתמש פרטי שאיני אחד מחבריו.	**Tampring**	**הצליח**
פרסום גליט תוך שינוי שם המסך לשם קצר מחמש תווים או ריק בפיד של משתמש אחר.	**Tampring**	**הצליח**
פרסום גליט תוך שינוי שם המסך לשם שאינו קיים במערכת בפיד של משתמש אחר.	**Tampring**	**הצליח**
פרסום גליט ללא תוכן [PATCHED].	**Tampring**	**הצליח**
פרסום גליט שתוכנו ארוך מ-140 תווים.	**Tampring**	**הצליח**
פרסום גליט בזמן עבר או עתיד.	**Tampring**	**הצליח**
ביצוע HTML Injection בשדה התוכן של בקשת פרסום גליט.	**Tampring**	**הצליח**
פרסום גליט תוך שינוי האווטאר לאווטאר שונה מהמוגדר במשתמש.	**Tampring**	**הצליח**
פרסום גליט תוך שינוי צבע הפונט.	**Tampring**	**הצליח**
פרסום גליט תוך שינוי צבע הרקע לצבע שאינו קיים במערכת.	**Tampring**	**הצליח**
פרסום גליט תוך שינוי שם המסך לשם קצר מחמש תווים או ריק בפיד שלי.	**Tampring**	**לא הצליח**
פרסום גליט תוך שינוי שם המסך לשם שאינו קיים במערכת בפיד שלי.	**Tampring**	**לא הצליח**
פרסום גליט ללא אווטאר.	**Tampring**	**לא הצליח**
פרסום גליט ללא צבע פונט.	**Tampring**	**לא הצליח**

פרסום גליט ללא צבע רקע.	Tampring	לא הצליח
פרסום גליט בפיד של משתמש שאינו קיים.	Tampring	לא הצליח
פרסום גליט תוך שינוי מזהה המפרסם למזהה של משתמש אחר.	Spoofing	לא הצליח
פרסום גליט תוך שינוי מזהה המפרסם למזהה לא קיים.	Spoofing	לא הצליח

מחקר נק' כניסה		
מספר הבקשה	**150**	
שם הבקשה בעברית	**הרשמה**	
דוגמא אמיתית	150#{gli&&er}{"registration_code":"11111","user":{"screen_name":"lorem_ipsum","avatar":"im4","description":"lorem_ipsum","privacy":"Public","id":-1,"user_name":"yona5","password":"yona5","gender":"Male","mail":"lorem_ipsum@lorem.ipsum"}##	
תפקיד הבקשה	הרשמה לאתר	
תיאור פרמטרים	**שם**	**שם**
	registration_code	קוד ההרשמה
	screen_name	שם המסך של המשתמש
	avatar	האווטאר של המשתמש
	description	התיאור של המשתמש
	privacy	פרטיות הפרופיל של המשתמש
	id	מזהה המשתמש
	user_name	שם המשתמש
	password	סיסמא
	gender	מין המשתמש
	mail	כתובת המייל של המשתמש
דוגמא אמיתית לתגובה	User registration 155# approved{gli&&er}{"screen_name":"lorem_ipsum","avatar":"im4","description":"lorem_ipsum","privacy":"Public","id":68815,"user_name":"yona5","password":"yona5","gender":"Male","mail":"lorem_ipsum@l##orem.ipsum"}	

תרחישי תקיפה לנק' כניסה תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה		
החולשה	**סוג החולשה (STRIDE)**	**הצליח / לא הצליח**
ביצוע הרשמה עם קוד הרשמה קצר מ-5 תווים.	Tampring	הצליח
ביצוע הרשמה עם שם מסך קצר מ-5 תווים [PATCHED].	Tampring	הצליח
ביצוע הרשמה עם שם משתמש קצר מ-5 תווים [PATCHED].	Tampring	הצליח
ביצוע הרשמה עם כתובת מייל ריקה [PATCHED].	Tampring	הצליח
ביצוע הרשמה עם שם משתמש ריק.	Tampring	לא הצליח
ביצוע הרשמה עם שם מסך ריק.	Tampring	לא הצליח
ביצוע הרשמה עם קוד הרשמה ריק.	Tampring	לא הצליח

ביצוע הרשמה עם אווטאר ריק.	**Tampring**	**לא הצליח**
ביצוע הרשמה עם תיאור ריק.	**Tampring**	**לא הצליח**

מחקר נק' כניסה		
מספר הבקשה	**300**	
שם הבקשה בעברית	**חיפוש**	
דוגמא אמיתית	300#{gli&&er}{"search_entry":"lorem_ipsum","search_type":"SIMPLE"}##	
תפקיד הבקשה	חיפוש משתמש לפי שם מסך	
תיאור פרמטרים	**שם**	**הסבר**
	search_entry	ערך החיפוש
	search_type	סוג החיפוש
דוגמא אמיתית לתגובה	Entities search result{gli&&er}[{"screen_name":"Lorem ipsum dolor sit amet, consectetur 305# adipiscing elit. Sed do eiusmod tempor incididunt ut labore ","avatar":"im7","description":"asd","privacy":"Private","id":42982,"mail":"ssasd@gmail.com"},...]##	

תרחישי תקיפה לנק' כניסה תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה		
החולשה	**סוג החולשה (STRIDE)**	**הצליח / לא הצליח**
ביצוע חיפוש ריק.	**Tampring**	**הצליח**
חשיפת מזהה של משתמש וכתובת המייל של משתמש בעת ביצוע חיפוש.	**Information Disclosure**	**הצליח**
ביצוע SQL Injection בשדה ערך החיפוש של בקשת החיפוש.	**Information Disclosure**	**לא הצליח**

Glitter

מחקר נק' כניסה	
מספר הבקשה	**350**
שם הבקשה בעברית	**עדכון הגדרות**
דוגמא אמיתית	350#{gli&&er}{"screen_name":"lorem_ipsum","avatar":"im4","description":"lorem_ipsum","privacy":"Public","id":68793,"user_name":"json1","password":"1234","gender":"Male","mail":"lorem_ipsum@lorem.ipsum"}##
תפקיד הבקשה	עדכון הגדרות המשתמש
תיאור פרמטרים	**שם**: **הסבר** screen_name: שם המסך של המשתמש avatar: האווטאר של המשתמש description: התיאור של המשתמש privacy: פרטיות הפרופיל של המשתמש id: מזהה המשתמש user_name: שם המשתמש password: סיסמא gender: מין המשתמש mail: כתובת המייל של המשתמש
דוגמא אמיתית לתגובה	User setting update 355# approved{gli&&er}{"screen_name":"lorem_ipsum","avatar":"im4","description":"lorem_ipsum","privacy":"Public","id":68793,"user_name":"json1","password":"1234","gender":"Male","mail":"lorem_ipsum@lorem.ipsum","date##":"2026-09-26T06:10:33.743Z"}

תרחישי תקיפה לנק' כניסה

תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה

החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח
עדכון שם המסך לשם קצר מ-5 תווים [PATCHED].	**Tampring**	**הצליח**
חשיפת שם משתמש של משתמש אחר בעת ניסיון עדכון הגדרות לפי מזהה המשתמש.	**Spoofing** **Information Disclosure**	**הצליח**
עדכון שם המשתמש.	**Tampring**	**לא הצליח**
עדכון הסיסמא.	**Tampring**	**לא הצליח**
עדכון כתובת המייל לכתובת מייל ריקה.	**Tampring**	**לא הצליח**
עדכון שם המסך לשם מסך ריק.	**Tampring**	**לא הצליח**
עדכון האווטאר לאווטאר ריק.	**Tampring**	**לא הצליח**
עדכון התיאור לתיאור ריק.	**Tampring**	**לא הצליח**
עדכון הגדרות של משתמש אחר.	**Spoofing**	**לא הצליח**

Glitter

מחקר נק' כניסה		
מספר הבקשה	**720**	
שם הבקשה בעברית	**ביטול לייק**	
דוגמא אמיתית	720#{gli&&er}2150325##	
תפקיד הבקשה	ביטול לייק לגליט	
תיאור פרמטרים	**שם**	**הסבר**
	""	מזהה הלייק
דוגמא אמיתית לתגובה	Unlike publish approved{gli&&er}{"glit_id":164840,"user_id":68794,"id":2150325,"date":"2026-725###09-26T06:26:58.225Z"}	

תרחישי תקיפה לנק' כניסה תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה		
החולשה	**סוג החולשה (STRIDE)**	**הצליח / לא הצליח**
הסרת לייק שנעשה על ידי משתמש אחר.	**Spoofing**	**הצליח**
הסרת לייקים עד להגעת המונה לערך שלילי.	**Other**	**לא הצליח**

מחקר נק' כניסה		
מספר הבקשה	**760**	
שם הבקשה בעברית	**ביטול וואו**	
דוגמא אמיתית	760#{gli&&er}14342##	
תפקיד הבקשה	ביטול וואו לגליט	
תיאור פרמטרים	**שם**	**הסבר**
	""	מזהה הוואו
דוגמא אמיתית לתגובה	Unwow publish approved{gli&&er}{"glit_id":164848,"user_id":68794,"id":14342,"date":"2026-765###09-26T06:46:41.581Z"}	

תרחישי תקיפה לנק' כניסה תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה		
החולשה	**סוג החולשה (STRIDE)**	**הצליח / לא הצליח**
הסרת וואו שנעשה על ידי משתמש אחר.	**Spoofing**	**הצליח**
הסרת וואו עד להגעת המונה לערך שלילי.	**Other**	**לא הצליח**

Glitter

מחקר נק' כניסה		
מספר הבקשה	**200**	
שם הבקשה בעברית	**התנתקות**	
דוגמא אמיתית	200#{gli&&er}68794##	
תפקיד הבקשה	התנתקות מהאתר	
תיאור פרמטרים	**שם**	**הסבר**
	""	מזהה המשתמש
דוגמא אמיתית לתגובה	##User logout approved{gli&&er}205#	

תרחישי תקיפה לנק' כניסה תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה		
החולשה	**סוג החולשה (STRIDE)**	**הצליח / לא הצליח**
ניתוק משתמש פעמיים.	**Other**	**לא הצליח**
ניתוק משתמש מחובר אחר.	**Spoofing**	**לא הצליח**

מחקר נק' כניסה		
מספר הבקשה	**100**	
שם הבקשה בעברית	**התחברות**	
דוגמא אמיתית	100#{gli&&er}{"user_name":"json1","password":"1234","enable_push_notifications":true}##	
תפקיד הבקשה	התחברות לאתר	
תיאור פרמטרים	**שם**	**הסבר**
	user_name	שם המשתמש
	password	סיסמא
	enable_push_notifications	אישור קבלת התראות דחיפה
דוגמא אמיתית לתגובה	##Login received. Please complete ascii checksum.{gli&&er}105#	

תרחישי תקיפה לנק' כניסה תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה		
החולשה	**סוג החולשה (STRIDE)**	**הצליח / לא הצליח**
חשיפת סיכום הביקורת של משתמש בעת ניסיון התחברות.	**Spoofing** **Information Disclosure**	**הצליח**
התחברות עם סיסמא שגויה.	**Spoofing**	**לא הצליח**

Glitter

מחקר נק' כניסה		
מספר הבקשה	**110**	
שם הבקשה בעברית	**אותנטיקציה**	
דוגמא אמיתית	110#{gli&&er}693##	
תפקיד הבקשה	אימות זהות המשתמש בעת התחברות לאתר	
תיאור פרמטרים	**שם**	**הסבר**
	""	סיכום הביקורת של המשתמש
דוגמא אמיתית לתגובה	Authentication 115# approved{gli&&er}{"screen_name":"lorem_ipsum","avatar":"im4","description":"lorem_ipsum","privacy":"Public","id":68793,"user_name":"json1","password":"1234","gender":"Male","mail":"lorem_ipsu##m@lorem.ipsum","date":"2026-09-26T08:39:40.424Z"}	

תרחישי תקיפה לנק' כניסה

תרחישים הקשורים לפרמטר ספציפי או לעצם הבקשה

החולשה	סוג החולשה (STRIDE)	הצליח / לא הצליח
אימות זהות של משתמש עם סיכום ביקורת שגוי.	**Spoofing**	**לא הצליח**